

Manual 07 - Seguridad de IA y Controles del Ciclo de Vida

CANDIDATO CONTROLADO PARA QA DE PUBLICACION

Revisión de fuente controlada: f4b19cb81daea6053de41fb3454da4170cf6f397 | Idioma: es-419 | se mantienen los límites de autorización y parada/reversión.

Límite de seguridad y aseguramiento: Este manual educativo no demuestra que un sistema de IA sea seguro, conforme, certificado ni libre de vulnerabilidades explotables. Las decisiones sobre autorización, mínimo privilegio, parada/reversión, respuesta a incidentes, riesgo de proveedores y evidencia requieren juicio humano responsable.

Rutas de implementación y seguridad

Manual 07 — Rutas de Implementación de Seguridad y Ciclo de Vida de IA

Traducción de trabajo para revisión semántica humana. Este contenido conserva el límite de seguridad del maestro controlado: reducir riesgo no equivale a garantizar seguridad.

Esencial

Úsela para casos de uso de IA acotados y entornos más pequeños. Controles mínimos:

- inventario, responsable, propósito y procedencia de datos/modelos/componentes;
- modelo de amenazas y tratamiento de riesgos aprobado;
- identidades de mínimo privilegio y permisos explícitos de herramientas;
- protección de secretos y logging;
- desarrollo seguro y revisión de cambios;
- evaluación previa al despliegue y pruebas de seguridad;
- monitoreo, escalamiento de incidentes y procedimientos de rollback/detención;
- seguimiento de proveedores/componentes y evidencia de desmantelamiento.

Estructurada

Úsela para múltiples sistemas de IA, servicios cloud, RAG, modelos/APIs externos, datos regulados o impacto material de negocio. Agregue:

- revisión de límites de confianza a nivel de arquitectura;
- linaje de datos/modelos/proveedores;
- pruebas de inyección de prompts y límites de recuperación;
- pruebas de autorización de agentes/herramientas;
- escenarios de evaluación adversarial/red team;
- telemetría de seguridad y detección de anomalías;
- puertas de liberación documentadas y gobierno de excepciones;
- reevaluación recurrente después de cambios de modelo/datos/herramientas.

Mejorada

Úsela para despliegues de alto impacto, autónomos/agénticos, relevantes para seguridad operacional, de escala empresarial o altamente regulados. Agregue:

- desafío técnico independiente y pruebas especializadas;
- separación estricta de privilegios y aprobación de acciones de alto riesgo;
- sandboxing/contención y controles de egreso;
- evaluación continua y simulación de ataques;
- verificación de integridad de proveedores/componentes;
- ejercicios de resiliencia, failover, detención/kill y rollback;

- aceptación ejecutiva de riesgos y gobierno de incidentes materiales;
- retiro formal, conservación de evidencia y lecciones posteriores a incidentes.

Ruta de seguridad del ciclo de vida

Gráfico de memoria del Manual 07 1

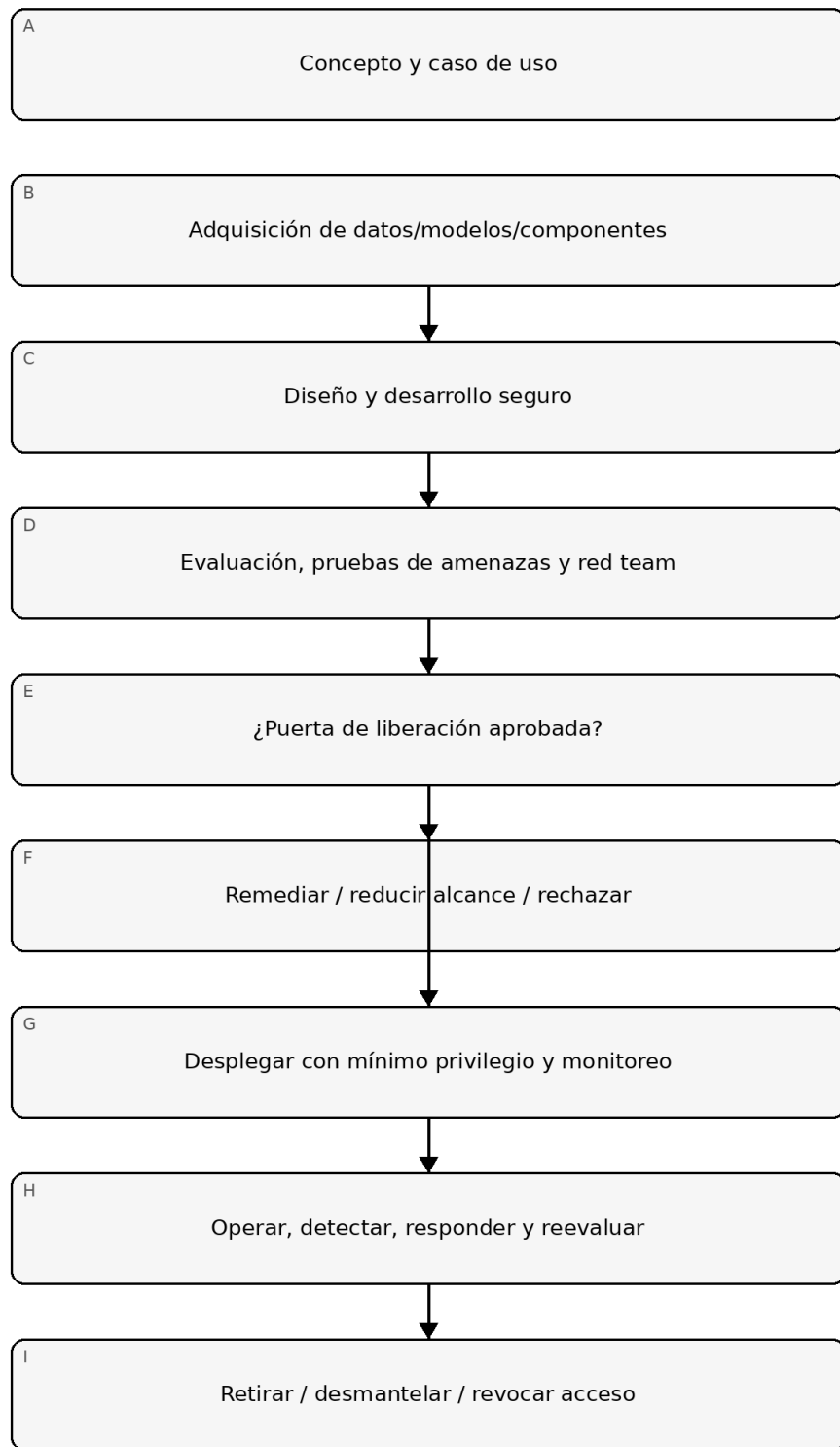


Figura 1. Gráfico de memoria de implementación

Explicación accesible: La seguridad comienza antes del desarrollo y continúa durante adquisición, diseño, pruebas, liberación, operación, respuesta a incidentes y retiro. Las puertas de liberación fallidas devuelven el trabajo a remediación en lugar de permitir un despliegue no controlado.

Cadena de confianza y autorización

Gráfico de memoria del Manual 07 2

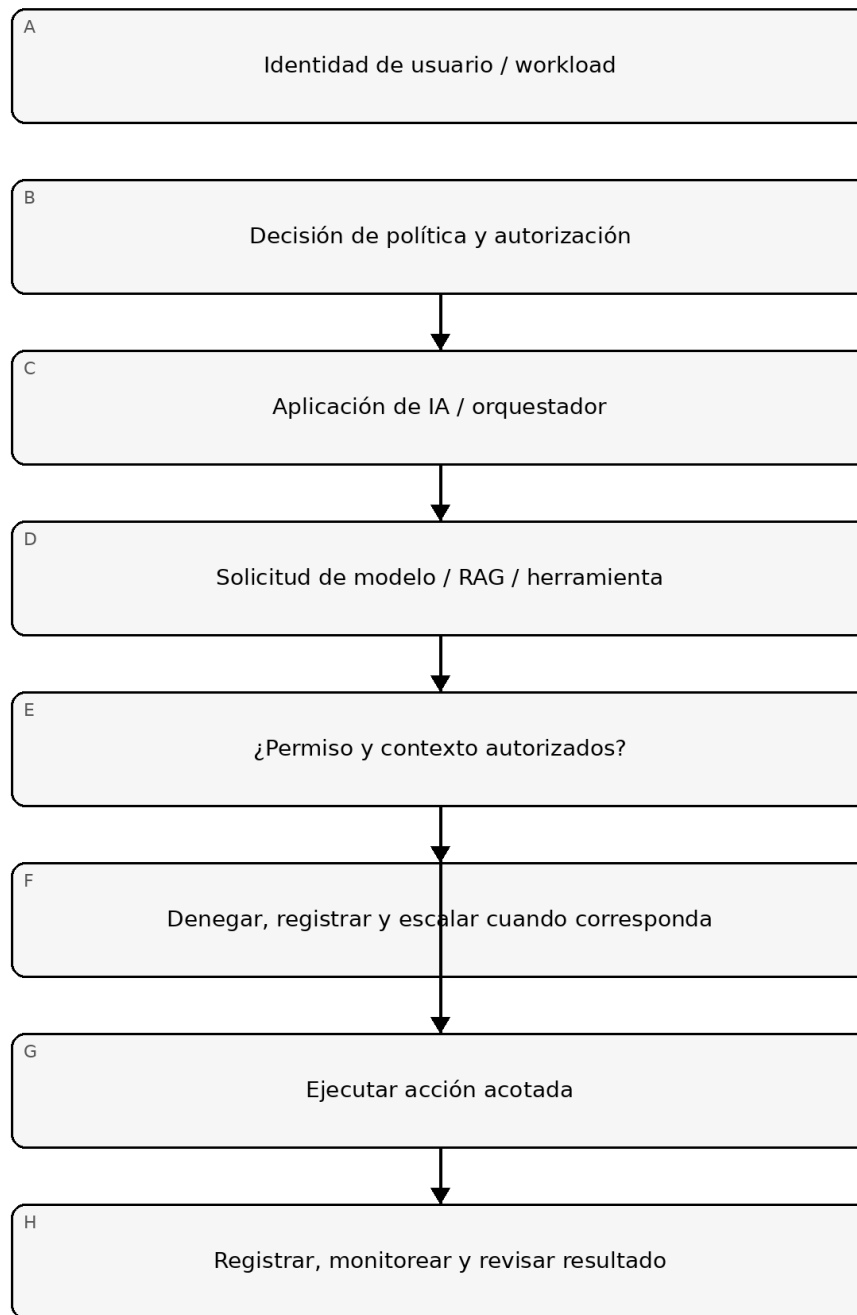


Figura 2. Gráfico de memoria de implementación

Explicación accesible: Toda acción de alto valor debe pasar por verificaciones explícitas de identidad, política, autorización y contexto. Las acciones denegadas fallan de forma cerrada; las permitidas permanecen acotadas y observables.

Cadena de evidencia y recuperación

Gráfico de memoria del Manual 07 3

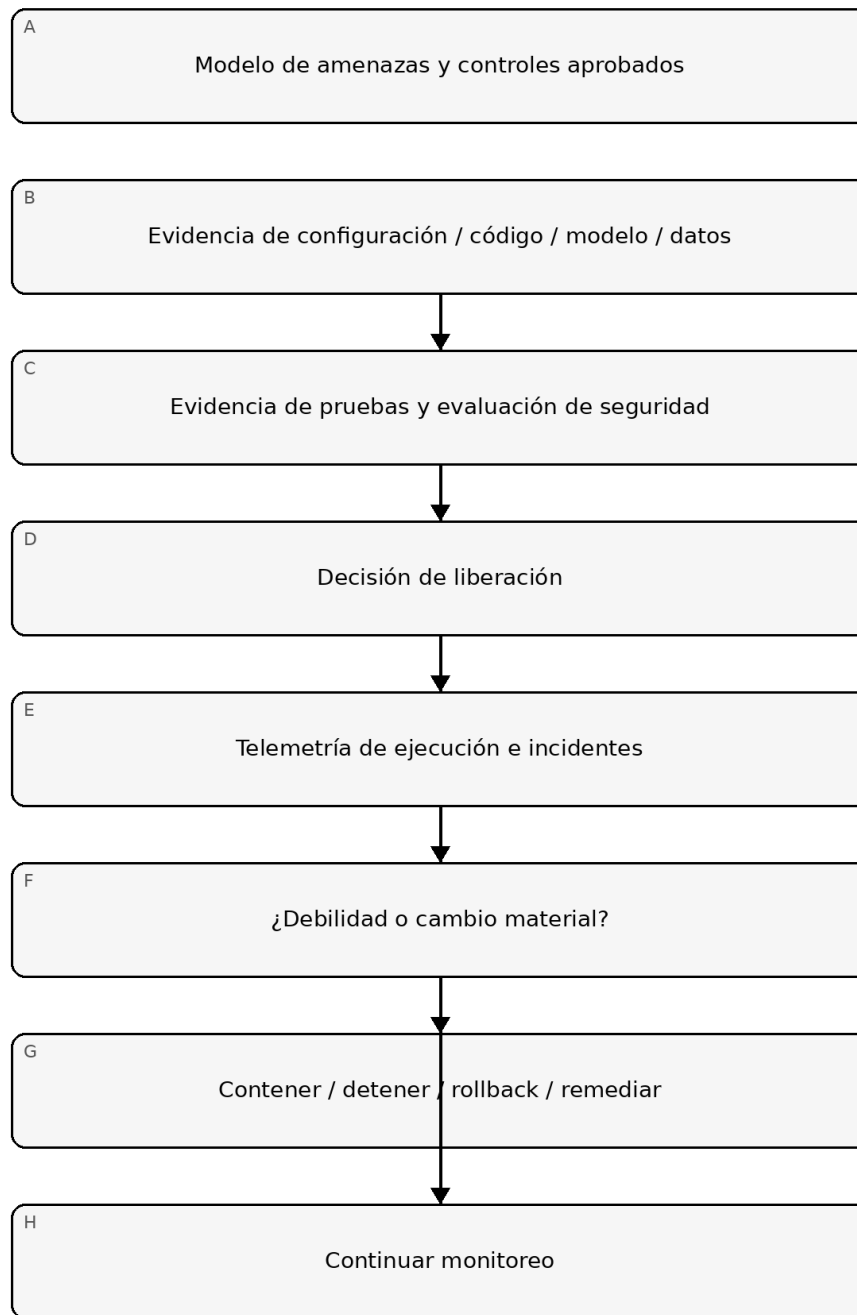


Figura 3. Gráfico de memoria de implementación

Explicación accesible: Las decisiones de seguridad son trazables desde modelos de amenazas hasta evidencia de implementación, pruebas, aprobación de liberación, telemetría de ejecución y recuperación. Las debilidades o cambios materiales activan contención y evidencia renovada, no aprobación obsoleta.

Familias de controles requeridas

1. Gobierno, propiedad, aprobación de casos de uso, apetito de riesgo y autoridad de cambio.
2. Inventario de activos, datos, modelos, prompts, almacenes vectoriales, herramientas, agentes, infraestructura y proveedores.
3. Modelado de amenazas y análisis de casos de uso indebido/abuso.
4. SDLC seguro e integridad de dependencias/componentes.
5. Procedencia, integridad, privacidad, clasificación y retención de datos.
6. Procedencia y control de versiones de modelos/componentes.
7. Identidad, autenticación, autorización, mínimo privilegio y aprobación de acciones privilegiadas.
8. Inyección directa/indirecta de prompts, envenenamiento RAG, uso indebido de herramientas y pruebas de control de agentes.
9. Secretos, claves, tokens, credenciales y confianza servicio-a-servicio.
10. Evaluación, pruebas de seguridad, red teaming, guardrails y criterios de liberación.
11. Monitoreo, logging, detección, respuesta a incidentes, contención, rollback y mecanismos de detención.
12. Riesgo de proveedores/servicios, requisitos contractuales/de evidencia y monitoreo de cambios de dependencias.
13. Retiro, desmantelamiento, revocación de accesos, disposición de datos y conservación de evidencia.

Límite de seguridad

La defensa en profundidad y las pruebas reducen el riesgo; no lo eliminan. El manual debe distinguir evidencia confirmada, suposiciones, áreas no probadas, riesgo residual y limitaciones conocidas.

Manual controlado de 32 capítulos

Capítulo 01 — Objetivo de seguridad y límite del ciclo de vida

La seguridad de IA debe cubrir el ciclo de vida completo del sistema y no únicamente el endpoint del modelo. El límite controlado incluye definición del caso de uso, adquisición de datos y modelos, diseño, desarrollo, evaluación, despliegue, operación, monitoreo, respuesta a incidentes, cambios y retiro.

Cada sistema debe contar con un objetivo de seguridad documentado vinculado con sus datos, acciones, usuarios, autonomía, conectividad externa y consecuencias de falla.

Capítulo 02 — Inventario de activos de IA

El inventario debe identificar modelos, conjuntos de datos, prompts, fuentes de recuperación, almacenes vectoriales, herramientas, agentes, APIs, cuentas de servicio, secretos, guardrails, componentes de monitoreo, entornos de alojamiento, proveedores y sistemas críticos aguas abajo.

Los registros de inventario deben incluir responsable, versión, ubicación, clasificación de datos, límite de autenticación, proveedor, exposición, autoridad de cambio y estado de retiro. Los componentes desconocidos crean superficie de ataque no administrada.

Capítulo 03 — Modelado de amenazas

El modelado de amenazas debe identificar activos, límites de confianza, actores, puntos de entrada, privilegios, dependencias y rutas plausibles de abuso. Las amenazas específicas de IA deben evaluarse junto con amenazas convencionales de aplicaciones, nube, identidad, datos y cadena de suministro.

Los escenarios deben incluir usuarios maliciosos, contenido de recuperación comprometido, agentes con privilegios excesivos, secretos expuestos, APIs inseguras, ejecución insegura de herramientas, datos envenenados, divulgación de modelos o prompts, compromiso de proveedores y comportamiento autónomo no previsto cuando corresponda.

Capítulo 04 — Desarrollo seguro y control de cambios

Los componentes de IA deben desarrollarse y modificarse mediante repositorios controlados, revisión, pruebas, gestión de dependencias, control de acceso y procesos de liberación. Los cambios en prompts, políticas, recuperación, herramientas y guardrails pueden ser significativos para la seguridad y no deben eludir el control de cambios por no ser código tradicional.

Los cambios materiales requieren reevaluar la evidencia de seguridad previa y pueden reabrir la aprobación de liberación.

Capítulo 05 — Procedencia de datos y modelos

Los equipos de seguridad deben poder identificar el origen de modelos, conjuntos de datos, pesos, adaptadores, paquetes, prompts y componentes externos, así como quién aprobó su uso.

Los registros de procedencia deben incluir origen, versión, evidencia de integridad cuando exista, límites de licencia o uso, proveedor, aprobación, historial de transformación y limitaciones conocidas. La procedencia apoya decisiones de confianza, pero no prueba que un componente sea seguro.

Capítulo 06 — Identidad, mínimo privilegio y autorización de herramientas

Los sistemas de IA que invoquen herramientas o acciones externas deben utilizar identidades explícitas y permisos de mínimo privilegio. El modelo no debe recibir credenciales amplias únicamente porque la aplicación requiera acceso a múltiples funciones.

Siempre que sea posible, la autorización debe imponerse fuera del modelo. Las acciones de alto impacto deben utilizar verificaciones de política, credenciales acotadas, límites transaccionales, aprobación humana u otros controles deterministas apropiados al riesgo.

Capítulo 07 — Inyección de prompts y contenido no confiable

La inyección directa e indirecta de prompts debe tratarse como amenaza de seguridad cuando una entrada no confiable pueda influir en comportamiento privilegiado, exponer información sensible, alterar instrucciones del sistema o provocar uso inseguro de herramientas.

Los controles pueden incluir aislamiento de contenido, límites de permisos, filtrado de recuperación, validación de salidas, listas permitidas de herramientas, separación de contexto, privilegios reducidos, pasos de confirmación y monitoreo. Ningún prompt o clasificador individual debe considerarse una defensa completa.

Capítulo 08 — Puerta de liberación de seguridad fail-closed

La liberación debe fallar de forma cerrada cuando falte evidencia crítica de seguridad, existan hallazgos materiales no resueltos sin tratamiento aprobado, no se hayan completado las pruebas adversariales requeridas, se requiera rollback o contención sin haberlos probado, o falte una revisión humana obligatoria.

Un workflow automatizado en verde respalda la decisión de liberación, pero no garantiza que el sistema sea seguro. La aprobación final continúa siendo una puerta controlada por humanos y los cambios materiales posteriores a la revisión reabren los controles de seguridad afectados.

Capítulo 09 — Seguridad de recuperación y fuentes de conocimiento

Las fuentes de recuperación deben tratarse como entradas influenciadas externamente. Los controles deben abordar admisión de fuentes, autoridad de escritura, validación de contenido, control de acceso, separación entre tenants, contenido obsoleto, exposición de datos sensibles y eliminación.

Los almacenes vectoriales e índices deben heredar controles apropiados de clasificación de datos, acceso, retención, logging y respaldo.

Capítulo 10 — Manejo de secretos y datos sensibles

Los secretos no deben incorporarse en prompts, código fuente, notebooks o contexto del modelo cuando existan alternativas más seguras. Las credenciales de servicio deben estar acotadas, rotarse, monitorearse y almacenarse mediante mecanismos aprobados de gestión de secretos.

Los logs, trazas, evaluaciones y artefactos de soporte también deben revisarse para detectar exposición no prevista de datos sensibles.

Capítulo 11 — Cadena de suministro de modelos y componentes

La revisión de seguridad debe incluir origen del modelo, paquetes, contenedores, adaptadores, conjuntos de datos, APIs, plugins, servicios de seguridad y dependencias de alojamiento. Los componentes deben versionarse y ser trazables para que los equipos de seguridad puedan evaluar el impacto de cambios de proveedor o componente.

Los cambios materiales de proveedores deben activar una reevaluación en lugar de heredarse silenciosamente.

Capítulo 12 — Evaluación y validación de seguridad

La evaluación de seguridad debe utilizar objetivos y resultados esperados basados en riesgo. La validación debe cubrir si los controles de acceso, límites de datos, permisos de herramientas, controles de recuperación, manejo de salidas, comportamiento de dependencias y restricciones operativas funcionan como se espera bajo condiciones representativas y de frontera.

La evidencia de pruebas debe registrar configuración, alcance, resultado, limitación y remediación.

Capítulo 13 — Desafío independiente

El desafío independiente debe probar si las suposiciones y límites de control siguen siendo válidos fuera de condiciones normales de operación. La revisión debe estar autorizada, acotada y basada en evidencia.

La actividad de desafío sin responsable de remediación ni validación de seguimiento no debe representarse como aseguramiento.

Capítulo 14 — Guardrails y controles deterministas

Los guardrails pueden reducir riesgo, pero deben combinarse con controles de seguridad deterministas cuando las consecuencias sean significativas. La autorización, validación de entradas, validación de salidas, listas permitidas, límites transaccionales, controles de red y aprobación humana pueden ofrecer una aplicación más fuerte que el comportamiento del modelo por sí solo.

Capítulo 15 — Supervisión humana para acciones sensibles a seguridad

Debe requerirse aprobación humana cuando las acciones automatizadas puedan generar impacto material de seguridad o negocio y el sistema no pueda limitar el riesgo de forma confiable mediante controles deterministas.

Los revisores necesitan suficiente contexto, tiempo, competencia y autoridad para rechazar o detener la acción. Un paso nominal de aprobación sin información significativa no constituye supervisión eficaz.

Capítulo 16 — Paquete de seguridad previo al despliegue

Antes de liberar, reúna el modelo de amenazas vigente, arquitectura, inventario de activos, resultados de validación, hallazgos abiertos, evidencia de proveedores, revisión de identidad/permisos, umbrales de monitoreo, plan de incidentes, plan de rollback/detención, excepciones y aprobaciones.

El paquete debe corresponder al candidato exacto de liberación y los cambios materiales deben reabrir la evidencia afectada.

Capítulo 17 — Endurecimiento del despliegue

El despliegue debe utilizar configuraciones aprobadas, identidades de mínimo privilegio, secretos protegidos, rutas de red controladas, logging, monitoreo y capacidad de rollback apropiados al riesgo.

El sistema desplegado debe compararse con el candidato de liberación validado para evitar introducir deriva relevante para la seguridad durante la promoción.

Capítulo 18 — Monitoreo y alertas

El monitoreo debe concentrarse en indicadores vinculados con riesgos conocidos: accesos inusuales, cambios de permisos, fallas repetidas de controles, actividad inesperada de herramientas, manejo de datos sensibles, cambios de dependencias, degradación de disponibilidad y excepciones de política.

Las alertas deben tener responsables, reglas de severidad, rutas de escalamiento y expectativas documentadas de respuesta.

Capítulo 19 — Logging y preservación de evidencia

Los logs relevantes para seguridad deben conservar contexto suficiente para apoyar investigaciones respetando al mismo tiempo privacidad y minimización de datos. Los registros útiles pueden incluir identidades, marcas de tiempo, referencias de modelo/configuración, invocaciones de herramientas, decisiones de política, referencias de recuperación y eventos de cambio.

La retención debe estar definida y el acceso a los logs controlado.

Capítulo 20 — Respuesta a incidentes

Los eventos de seguridad relacionados con IA deben integrarse al proceso de incidentes de la organización. Los planes de respuesta deben identificar opciones de contención, evidencia a preservar, contactos de proveedores, rutas de notificación, pasos de recuperación y criterios para suspender o restringir el servicio.

Capítulo 21 — Mecanismos de rollback y detención

Los sistemas con impacto material operativo o de seguridad deben contar con mecanismos de rollback o detención probados. La autoridad para invocarlos debe ser explícita.

Un control que exista únicamente en papel no debe acreditarse hasta que haya sido validado técnica y operacionalmente.

Capítulo 22 — Gestión de cambios y configuración

Los cambios en modelos, recuperación, prompts, instrucciones del sistema, herramientas, permisos, fuentes de datos, alojamiento, guardrails o proveedores pueden modificar la postura de seguridad. Los registros de cambio deben clasificar la materialidad e identificar qué validación previa continúa siendo válida.

Capítulo 23 — Gobierno de excepciones

Las excepciones de seguridad deben registrar el requisito no satisfecho, justificación de negocio, controles compensatorios, responsable, riesgo residual, aprobador, fecha de expiración y requisito de monitoreo.

Las excepciones de alto riesgo no deben convertirse en permanentes mediante extensiones administrativas repetidas sin reevaluación.

Capítulo 24 — Reevaluación periódica de seguridad

La reevaluación periódica debe examinar si amenazas, dependencias, accesos, uso de datos, estado de proveedores, comportamiento operativo y suposiciones previas continúan siendo válidos.

La evidencia debe mostrar qué se revisó, qué cambió, qué continúa siendo aceptable y qué acción adicional se requiere.

Capítulo 25 — Cambio de proveedores y dependencias

Los cambios de proveedor o dependencia deben evaluarse por su efecto en seguridad antes de adoptarse. Los cambios relevantes incluyen alojamiento, versión del modelo, arquitectura del servicio, procesamiento de datos, subprocesadores, métodos de acceso, logging, controles de seguridad y compromisos contractuales de notificación.

Capítulo 26 — Resiliencia y operación degradada

La planificación de seguridad debe considerar cómo se comporta el sistema cuando modelos, APIs, recuperación, monitoreo o servicios externos se degradan o no están disponibles. Los modos alternos no deben eludir silenciosamente controles de seguridad, aprobación o protección de datos.

Capítulo 27 — Consideraciones de respaldo y recuperación

La planificación de recuperación debe identificar qué configuraciones, prompts, políticas, índices, credenciales, evidencia y dependencias son necesarias para restaurar un estado controlado conocido. Los procedimientos de recuperación deben validarse en proporción a la criticidad.

Capítulo 28 — Retiro y desmantelamiento

El retiro debe revocar identidades, credenciales e integraciones; deshabilitar endpoints; eliminar o archivar datos conforme a requisitos; preservar evidencia obligatoria; cerrar acceso de proveedores; y documentar obligaciones no resueltas.

Capítulo 29 — Métricas de seguridad e informes de gestión

Las métricas deben estar vinculadas con decisiones. Los informes útiles pueden incluir hallazgos materiales, excepciones, estado de reevaluación, tendencias de incidentes, cambios de dependencias, cobertura de validación, remediación vencida e indicadores de salud de controles.

Capítulo 30 — Limitaciones del aseguramiento de seguridad

Ninguna suite automatizada de pruebas, checklist de controles, revisión de seguridad o workflow del repositorio puede establecer que un sistema de IA esté libre de debilidades. Las declaraciones de aseguramiento deben identificar alcance, período, evidencia y limitaciones que las respaldan.

Capítulo 31 — Mejora continua

Las lecciones de incidentes, casi incidentes, pruebas, cambios de proveedores, retroalimentación de usuarios y fallas de controles deben retroalimentar modelos de amenazas, planes de validación, controles operativos y capacitación.

Capítulo 32 — Límite de liberación del manual

Antes de publicar este manual deben completarse la verificación de fuentes, el maestro controlado completo en inglés, la revisión técnica/de seguridad, la revisión semántica de es-419 y pt-BR, la revisión de gráficos/accesibilidad, QA documental y por página, procedencia, auditoría de seguridad del repositorio y la Aprobación Humana Final de Liberación.

Los cambios materiales de contenido posteriores a la aprobación humana reabren los controles afectados.